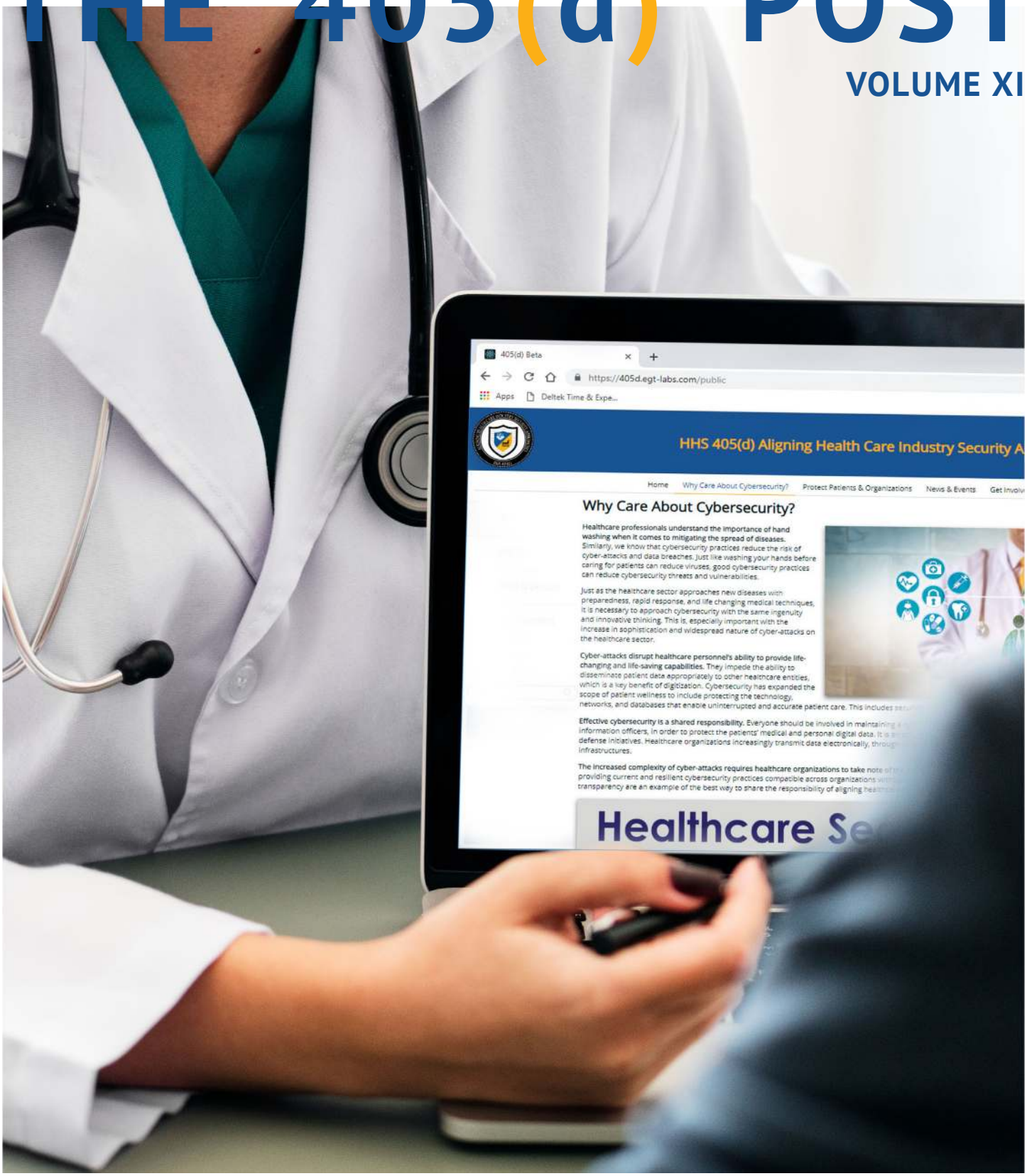
THE 405(d) POST

VOLUME XI



HHS 405(d)
Aligning Health Care
Industry Security Approaches

The Evolution of Risk to Protected Health Information (PHI) and Patient Safety

By Gerry Blass, 405(d) Task Group Member

Early On

In the 70s and 80s, healthcare organizations started to migrate their patient management information from hardcopy to electronic, either on shared mainframes such as a Storage Management Subsystem (SMS) and McAuto or on microprocessors. The user workstations had no intelligence and were known as "dumb terminals." There were limited locations of electronic identifiable health information. There was no motivation to sell identifiable health information.

The Beginning of Motivation and Opportunity

During the 1990s, the implementation of local and wide area networks, intelligent workstations, and distributed servers resulted in increases in risk to unauthorized access. Several breach incidents occurred, and even celebrities had their data exposed. **Hospital employees even sold medical records of accident victims to lawyers.** Thus, a trend began of increased motivation and opportunity to sell health information for monetary gain.

Health Insurance Portability and Accountability Act (HIPAA)

The initial objective of HIPAA was for administrative simplification of insurance claims through standardized electronic coding and was signed into law during the Clinton Administration in 1996. The HIPAA privacy and security rules were published in 2000 and 2003 respectively due to incidents and increased vulnerabilities. Most breach incidents in the early 2000s were caused by internal healthcare employees, both intentional and accidental which, as we know, is still a problem today.

Health Information Technology for Economic and Clinical Health (HITECH) Act

HITECH was enacted as part of the American Recovery and Reinvestment Act of 2009 and was signed into law on February 17, 2009, to promote the adoption and meaningful use of health information technology. The act included the Breach Notification rule, which brought penalties and civil suits into play for incidents that were due to negligence.

Meaningful Use (MU)

The many years and stages of MU resulted in significant migration from hard copy to electronic medical records through the adoption of electronic medical records systems (EMRs). The increase in electronic health information locations and the lack of adequate controls to protect it resulted in cybersecurity attacks. The opportunity for successful attacks was high, along with the motivation.

Omnibus

The HITECH Omnibus final rule, published in 2013, increased penalties and civil suits for both covered entities (CEs) and third-party vendors (BAs). It also updated breach determinations based on the probability of compromising Protected Health Information (PHI) and defined timeframes for reporting notifications.

Fast Forward

Over the past seven-plus years, the healthcare industry has continued to be the number one target for cybersecurity attackers, now known as "bad actors." With limited funds and staff, many healthcare organizations are at a disadvantage in managing risk. Additionally, the scope and complexity of risk continually increased due to several variables that increased the number of locations of potentially vulnerable PHI. It is difficult for healthcare organizations to keep up with advanced threats. Yet, the costs of not keeping up can be even higher from a monetary and **patient safety** standpoint. With Health Information Exchanges (HIEs), Internet of Things (IOTs), Application Programming Interfaces (APIs), Interoperability, Information Blocking, the Pandemic (remote workforce and telehealth), and breaches caused by third parties, the number of locations of PHI are now geometric, and thus the number of fish in the sea is high for phishing attacks. **What started as perhaps four places for identifiable health information and no motivation for an attack in the 70s and 80s is now unlimited locations and motivation.** Also, the bad actors know that there is minimal risk of getting caught for their crime.

Ransomware

The ultimate motivation for bad actors today is to make money with ransomware. So, what goes around comes around. **What started as the most significant risk being with the internal workforce back in the 90s is still the same today with phishing attacks.** Healthcare organizations continually train their workforce with mock phishing exercises, and there are still significant vulnerabilities for falling prey to an attack. Today's motto is **"It is not a question of if... it is a question of when".**

When an attack takes down a healthcare organization and its medical devices, **patient safety and lives are then at stake**—the ultimate feared outcome.

Recent Attacks

The number of ransomware attacks continues to increase, resulting in large ransoms paid and the potential for extended periods of downtime that have happened and have crippled critical structures and continue to happen. Recent examples include:

- Solarwinds, which impacted a large number of third-party vendors (BAs) and their clients.
- University of Vermont Health System—resulted in over 30 days of complete shutdown and diversion of patients, such as chemo and dialysis, to other healthcare facilities.
- The Colonial Pipeline—an example of how a ransomware attack can cripple our infrastructure.

The Disaster Recovery and Business Continuity (DRBC) Domino Effect

Traditional DRBC plans based on The National Institute of Standards and Technology (NIST) from 10 years ago included scenarios and business impact of a reasonable outage of no more than 72 hours. Business impact analysis (BIA) included variables resulting in application ratings of high, medium, and low criticality. Organization downtime procedures were created based on the BIA. Today, the 72-hour downtime time frame is no longer reasonable. **The incidents listed above, as noted, resulted in more extended periods of downtime, such as 30 days or more.** Healthcare organizations are now re-evaluating their plans to take the potentially extended downtime timeframes into account. The possible scenarios are dramatic and **require a strategy beyond just systems to include** critical business decisions that could significantly impact operations. Examples include: when to pay a ransom, notify local police and the FBI, shutter parts or all of the organization, and divert patients.

Consensus-based Mitigations

HHS 405(d) Program- Health Industry Cybersecurity Practices (HICP)

Healthcare organizations should consider implementing HICP to manage threats and implement controls that reduce risk. HHS convened the 405(d) Task Group to publish the top five threats and top 10 recognized security practices scoped for small, medium, and large organizations. The first version was published in December 2018. Updates will continue to occur. There are several updates expected in the future. HICP is aligned to the NIST Cybersecurity Framework (CSF) and is mapped to other frameworks.

Click here to view HICP.

PL 116-321

The 405(d) Program is encouraged by the passing of H.R. 7898 (public law PL 116-321) which calls out "approaches promulgated under Section 405(d) of the Cybersecurity Act of 2015" as 'recognized security practices'. We would like to acknowledge the public-private partnership of the 405(d) Task Group for their hard work, dedication, and willingness to collaborate with the U.S. Department of Health and Human Services (HHS) to develop cybersecurity resources, products, and tools. The 405(d) Program is focused on providing the Healthcare and Public Health (HPH) Sector with useful and impactful resources, products, and tools that help raise awareness and provide vetted cybersecurity practices, which drive behavioral change and move towards consistency in mitigating the most relevant cybersecurity threats to the sector. The public-private partnership is vital to the 405(d) Program as we work towards achieving our mission and ultimately aligning healthcare security approaches across the entire HPH sector. The passing of this bill not only highlights the work of the 405(d) Task Group and all of its efforts, but it is also another step forward in encouraging HPH entities to continue to focus on cybersecurity practices that will help protect their organizations and their patients. Cyber Safety is Patient Safety. The program continues to work with HHS partners to identify impacts and approaches to ensure all of HHS is working together in response to this new legislation.

The Future

Threat landscapes will continue to change as technology and other variables evolve. The number of locations of PHI will continue to increase. **The importance of keeping a DRBC plan up to date and tested will be more critical.** By doing so, healthcare organizations will make important decisions, such as moving applications to a cloud host, etc., where DRBC plans and procedures are managed remotely by companies whose whose responsibilities include protecting the confidentiality, integrity, and availability of PHI. **Information sharing amongst healthcare organizations about threats and vulnerabilities is and will continue to be a must.** The bad actors share information. Organizations such as ISAOs (Information Sharing and Analysis Organizations) and ISACs (Information Sharing and Analysis Centers®) help healthcare organizations' attempts to stay one step ahead of the bad actors.

405(d) HICP in the Spotlight

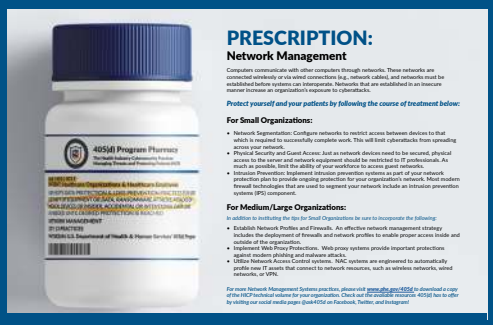
Network Management

Computers communicate with other computers through networks.
These networks are connected wirelessly or via wired connections (e.g., network cables), and networks must be established before systems can interoperate. Networks that are established in an insecure manner increase an organization's exposure to cyberattacks. Proper cybersecurity hygiene ensures that networks are secure and that all networked devices access networks safely and securely. Even if network management is provided by a third-party IT support vendor, the organization must understand key aspects of proper network management and ensure that they are included in contracts for these services.

For small, medium, and large organizations, an effective network management strategy includes the deployment of firewalls to enable proper access inside and outside of the organization. Firewall technology is far more advanced than standard router-based access lists and is a critical component of modern network management. Organizations should deploy firewall capabilities in the following areas: on wide area network (WAN) pipes to the internet and perimeter, across data centers, in building distribution switches, in front of partner WAN or Virtual Private Network (VPN) connections, and over wireless networks.

There should be clear boundaries that determine how traffic is permitted to move throughout the organization, including a default-deny ruleset whenever possible. At the perimeter, inbound and outbound, rules must be configured with a default-deny ruleset to limit accidental network exposures. This often-complicated process can be achieved by establishing security zones through network segmentation.

Tip: Consider limiting the outbound connections permitted by assets in your organization. This can be a challenge to implement across the board. However, for zones of high sensitivity egress limiting can prevent malicious callbacks or data exfiltration.



PRESCRIPTION:
Network Management

Computers communicate with other computers through networks. These networks are connected wirelessly or via wired connections (e.g., network cables), and networks must be established before systems can interoperate. Networks that are established in an insecure manner increase an organization's exposure to cyberattacks.

Protect yourself and your patients by following the course of treatment below:

For Small Organizations:

- Network Segmentation: Configure networks to restrict access between devices to that which is required to successfully complete work. This will limit cyberattacks from spreading across your network.
- Guest Access: Employee and Guest Access: Just as network devices need to be secured, physical access to the server and network equipment should be restricted to IT professionals. As much as possible, limit the ability of your workforce to access guest networks.
- Intrusion Prevention: Implement intrusion prevention systems as part of your network protection plan to provide ongoing protection for your organization's network. Most modern firewall technologies that are used to segment your network include an intrusion prevention systems (IPS) component.

For Medium/Large Organizations:

In addition to instituting the tips for Small Organizations be sure to incorporate the following:

- Establish Network Profiles and Firewalls. An effective network management strategy includes the deployment of firewalls and network profiles to enable proper access inside and outside of the organization.
- Implement Web Proxy Protections. Web proxy systems provide important protections against modern phishing and malware attacks.
- Utilize Network Access Control systems. NAC systems are engineered to automatically profile new IT assets that connect to network resources, such as wireless networks, wired networks, or VPN.

For more Network Management Systems practices, please visit www.aha.org/405d to download a copy of the HICP technical volume for your organization. Check out the available resources 405(d) has to offer by visiting our social media pages @ask405d on Facebook, Twitter, and Instagram!

Network Management Prescription Poster

Firewall rules may change when technology is added or removed. A robust change management process should include reviewing every firewall to identify necessary changes. These change requests should comply with standard IT operations change management processes and be approved by cybersecurity departments before any firewall is modified. As part of standard rule management for firewalls, it is important to periodically review firewalls to ensure they are properly structured as required by cybersecurity teams. Consider a monthly or quarterly review of the highest-risk rulesets.

To learn more mitigating practices check out the Network Management Prescription Poster and the Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients publication!

405(d) Chronicles

By Mark Jarrett, MD, MBA, MS- 405(d) Task Group Member

The last 16 months have been a stress test for healthcare, not only in the United States, but the whole world. Treatment of critically ill COVID-19 patients has dramatically improved. We are now returning to normal daily life due to the scientific miracle of having vaccines available less than 12 months from the start of the pandemic. New medications have saved lives. The heroism of our patient caregivers can never be over-recognized. These dramatic successes have revealed an underlying foundation—**the need for valid and reliable data.**

We all remember the first few months in the spring of 2020 when new treatments were touted based on case reports of 50 patients, then used in tens of thousands. Done out of desperation, it was understandable, but from a scientific basis, illogical. We learned again that only randomized controlled studies will give us the appropriate evidence to securely decide what we should use for treatments. Thus, the need for data, **especially shared data,** across the country and the world. Similarly, operational decisions, such as where to transfer patients when hospitals were overwhelmed and the concept of load balancing, needed **timely and accurate data.** Constructing dashboards and using predictive analysis was critical during surges. There are many lessons learned from the pandemic that need to be applied to the "new normal" post-COVID healthcare environment with the need to be **data driven.**

The thirst for good data can only be quenched by having robust, valid, and reliable databases, common terminology, and the **agreement to share.** In our current environment, this can only safely occur if data and communications are secure. We have already seen nation states attempt to steal vaccine intellectual property. They could have injected malware to slow or halt vaccine research or production. **Unaltered and safe data is required** by clinicians to determine the best clinical guidelines. This reinforces the need for all of healthcare to be constantly vigilant and **practice cyber-hygiene.**

It is everyone's responsibility to be a guardian of our data. It's important to remember to upgrade your operating systems, apply and test security patches as quickly as possible, use secure passwords and change regularly, and beware of phishing hooks. *Look before you click.* Also, for a more in-depth knowledge on keeping data secure, I suggest every physician and administration staff read the *Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients* main document to learn more about your role in the effort to keep our data safe.

Happening Around Us

Hackers hit major software provider Kaseya

The Washington Post reported that a sprawling ransomware attack that hit hours before the beginning of the July Fourth holiday weekend has already affected hundreds of businesses and is likely to hit many more, researchers said. On Saturday morning, the information technology company Kaseya confirmed that it had suffered a "sophisticated cyberattack" on its VSA software — a set of tools used by IT departments to manage and monitor computers remotely. The company said that only about 40 customers had been affected.

Researchers said that the hacker group behind this attack was a group called REvil, which had previously attacked meat processor JBS this spring. Instead of a careful, targeted attack on a single large company, this hack seems to have used managed-service providers to spread its harm indiscriminately through a huge network of smaller companies. Unlike most ransomware attacks, it doesn't appear that REvil tried to steal sensitive data before locking its victims out of their systems.

Click here to read the full article at the Washington Post.

UF Health employees: Cyber attack now impacting patient care

Several employees at University of Florida Health in The Villages and Leesburg Hospital told a local news station that a recent data breach is negatively impacting patient care. Two cybersecurity firms WESH 2 News spoke with say it appears to be a ransomware attack, in which a phishing email is sent to staff and, when opened, system records are locked and remain inaccessible until money is paid. Since then, employees are using pen and paper and phone calls to keep and share records. Two employees told WESH 2 News they are without access to patient computer files and are not able to know what drugs to give, and what allergies to avoid. Because the two campuses affected in the UF Health chain, The Villages and Leesburg, are on different and older computer systems, hospitals have to call pharmacies to get patient prescription histories. Another problem, according to these employees is that they have long delays in getting lab reports. There is no word as to whether UF Health intends to pay ransom to the hackers.

Learn how to protect your patients and organization from phishing and ransomware attacks with the Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients publication.

Click here to read the full story from WESH 2 News.

Sensitive medical, financial data exposed in extortion of Massachusetts hospital

A hospital in Massachusetts quietly paid off a ransomware gang after a February hack that exposed patients' sensitive medical and financial data, the hospital said in a May 28 statement. Sturdy Memorial Hospital, a 126-bed facility in the city of Attleboro, said that the information exposed in the hacking incident may have included insurance claim numbers, medical history, treatment information, Social Security numbers, bank routing numbers and credit card numbers and security codes, among other data. Other Massachusetts health providers with which Sturdy Memorial Hospital has worked were swept up in the incident. The breach affected data belonging to patients of Harbor Medical Associates, South Shore Medical Center and providers affiliated with South Shore Physician Hospital Organization, according to the statement. Nearly four months after detecting the hackers—and a month after discovering the data that might have been exposed—Sturdy Memorial said it is notifying victims of the incident via mail. The hospital is offering breach victims free credit monitoring, a standard practice for hacked companies that consumer advocates say needs to be strengthened. The hack of Sturdy Memorial is an example of how ransomware criminals have increasingly used a double-edged extortion tactic to pressure victims to pay—a technique that involves first stealing data from networks, then encrypting it.

Looking for mitigation tactics to prevent accidental data breach within your healthcare organization? Check out the Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients publication.

Click here to read the full story from CyberScoop.

Other Federal Resources

CISA

- Fact Sheet—Rising Ransomware Threat to Operational Technology Assets
- Risk to Critical Infrastructure: Telecommunications Central Offices

HC3

- Ransomware Trends 2021
- API Securtiy for Healthcare
- Vulnerabilities Reported by MesaLabs for AmegaView
- New Phishing Campaign Launched by SOLARWINDS Attackers
- Overview of Conti Ransomware
- News of Interest to the Health Sector

Upcoming Events

Join us for our August Spotlight Webinar titled "Healthcare's Enterprise Cyber Risk Management Imperative" on August 12, 2021!

Follow us!

Facebook
Instagram
Twitter
LinkedIn

Check out our website at 405d.hhs.gov!

About The 405(d) Post

This newsletter is for information purposes only and aims to broaden awareness and align healthcare security approaches. The news articles represented in this newsletter are chosen at random to foster awareness and are not in promotion of any news organization. The "A Word from the Task Group" and the "405(d) Chronicles" is written by a different 405(d) Task Group Member each issue and does not reflect the views of HHS as a whole. All Task Group Members have been invited to contribute to this newsletter.

Need To Contact Us? Email us at cisa405d@hhs.gov